

HIPAA Compliance Mapping — MediConnect

Control Mapping Table

#	HIPAA Requirement	Control Description	Finding	Remediation	Evidence	Status
1	§164.312(a)(1) — Access Control	Implement technical policies to allow access only to authorized persons	AS-01, AS-03, AS-04, AS-06	Room ownership check, prescription ownership, JWT userId, admin registration lock	Burp Repeater before/after screenshots	Compliant
2	§164.308(a)(4) — Information Access Management	Implement policies for authorizing access to ePHI	AS-05, AS-06	Role middleware on all routes, admin role restricted	Route-level <code>authorizeRoles()</code> middleware	Compliant
3	§164.312(d) — Person or Entity Authentication	Verify identity of users seeking access	—	JWT-based authentication with bcrypt password hashing	<code>authMiddleware.js</code> , <code>bcryptjs</code> usage	Compliant
4	§164.312(a)(2)(i) — Unique User Identification	Assign unique identifier to each user	—	Auto-increment <code>id</code> in users table, email uniqueness constraint	Database schema	Compliant
5	§164.312(a)(2)(iii) — Automatic Logoff	Terminate sessions after inactivity	AS-07	JWT expires after 24 hours, <code>HttpOnly</code> cookies	Token expiry in JWT config	Partially Compliant
6	§164.312(c)(1) — Integrity	Protect ePHI from improper alteration/destruction	AS-03	Prescription modification restricted to prescribing doctor	Doctor ownership check in <code>endPrescription</code>	Compliant

#	HIPAA Requirement	Control Description	Finding	Remediation	Evidence	Status
7	§164.312(e)(1) — Transmission Security	Guard against unauthorized access during transmission	SG-02	HTTPS enforcement, Helmet security headers, CORS restrictions	helmet() middleware, CORS config	Partially Compliant
8	§164.308(a)(1)(ii)(D) — Information System Activity Review	Implement procedures to review system activity logs	—	Structured security logging with JSON format	security.log, alerts.log	Compliant
9	§164.308(a)(5)(ii)(C) — Log-in Monitoring	Monitor login attempts and report discrepancies	AS-08	Brute-force detection: 5 failed attempts in 5 minutes triggers CRITICAL alert	alerts.log with BRUTE_FORCE_DETECTED	Compliant
10	§164.308(a)(6) — Security Incident Procedures	Implement policies for responding to security incidents	—	Incident Response Playbook created for PHI breach via Chat IDOR	incident_response_playbook.md	Compliant
11	§164.312(b) — Audit Controls	Implement hardware/software mechanisms to record and examine access	—	Security logger captures auth, authz, AI events, sensitive access with PII masking	securityLogger.js, security.log	Compliant
12	§164.308(a)(8) — Evaluation	Perform periodic technical/nontechnical evaluation	—	SAST (Semgrep), SCA (npm audit), secret scanning (gitleaks), manual pen testing (Burp)	Scan reports, Burp evidence	Compliant
13	§164.312(a)(2)(iv) — Encryption and Decryption	Encrypt ePHI at rest	—	Passwords bcrypt-hashed; DB not encrypted at rest	DB default storage (TDE planned)	Gap

#	HIPAA Requirement	Control Description	Finding	Remediation	Evidence	Status
14	§164.308(a)(3) — Workforce Security	Ensure appropriate access for workforce members	AS-06	Self-registration limited to patient/doctor; admin created via DB only	validRoles check in authController	Compliant

Compliance Summary

Status	Count	Percentage
Compliant	11	79%
Partially Compliant	2	14%
Gap	1	7%

Gaps & Partial Compliance Details

Control	Gap	Mitigation Plan
§164.312(a)(2)(iii) — Auto Logoff	No server-side token revocation	Implement token blacklist with Redis (future)
§164.312(e)(1) — Transmission Security	TLS not enforced in development; DB SSL uses <code>rejectUnauthorized: false</code>	Enable strict TLS in production deployment
§164.312(a)(2)(iv) — Encryption at Rest	Database not encrypted at rest (PostgreSQL default)	Enable PostgreSQL TDE or use encrypted volumes in production

Live Control Demonstration

Demonstrated Control: Log-in Monitoring (HIPAA §164.308(a)(5)(ii)(C))

Under the HIPAA Security Rule (45 CFR § 164.308(a)(5)(ii)(C)), covered entities and their business associates must establish procedures for monitoring login attempts and reporting discrepancies (such as brute-force password guessing or abnormal authentication spikes).

Demonstrated Rule: Detection of 5 failed login attempts from the same IP address within a 5-minute sliding window.

Alert Output (`backend/logs/alerts.log`):

```
{
  "level": "CRITICAL",
  "category": "BRUTE_FORCE_DETECTED",
  "ip": "::1",
  "attemptCount": 5,
  "windowMinutes": 5,
  "message": "5 failed login attempts from ::1 in 5 minutes – possible brute-force attack"
}
```

This live demonstration satisfies:

1. **PRD Section 16 & 20:** Implementation and live demonstration of a security detection alert.
2. **HIPAA Specification §164.308(a)(5)(ii)(C):** Automatic discrepancy alerting on suspicious authentication activity.